Lab02_Group9_SmartCampus

Owner: Amina Rashid
Reviewer: Muniba Khan
Contributors: Salika Bibi, Iram Shehzadi
Date Generated: Tue Oct 27 2026



OWASP Threat Dragon

Executive Summary

High level system description

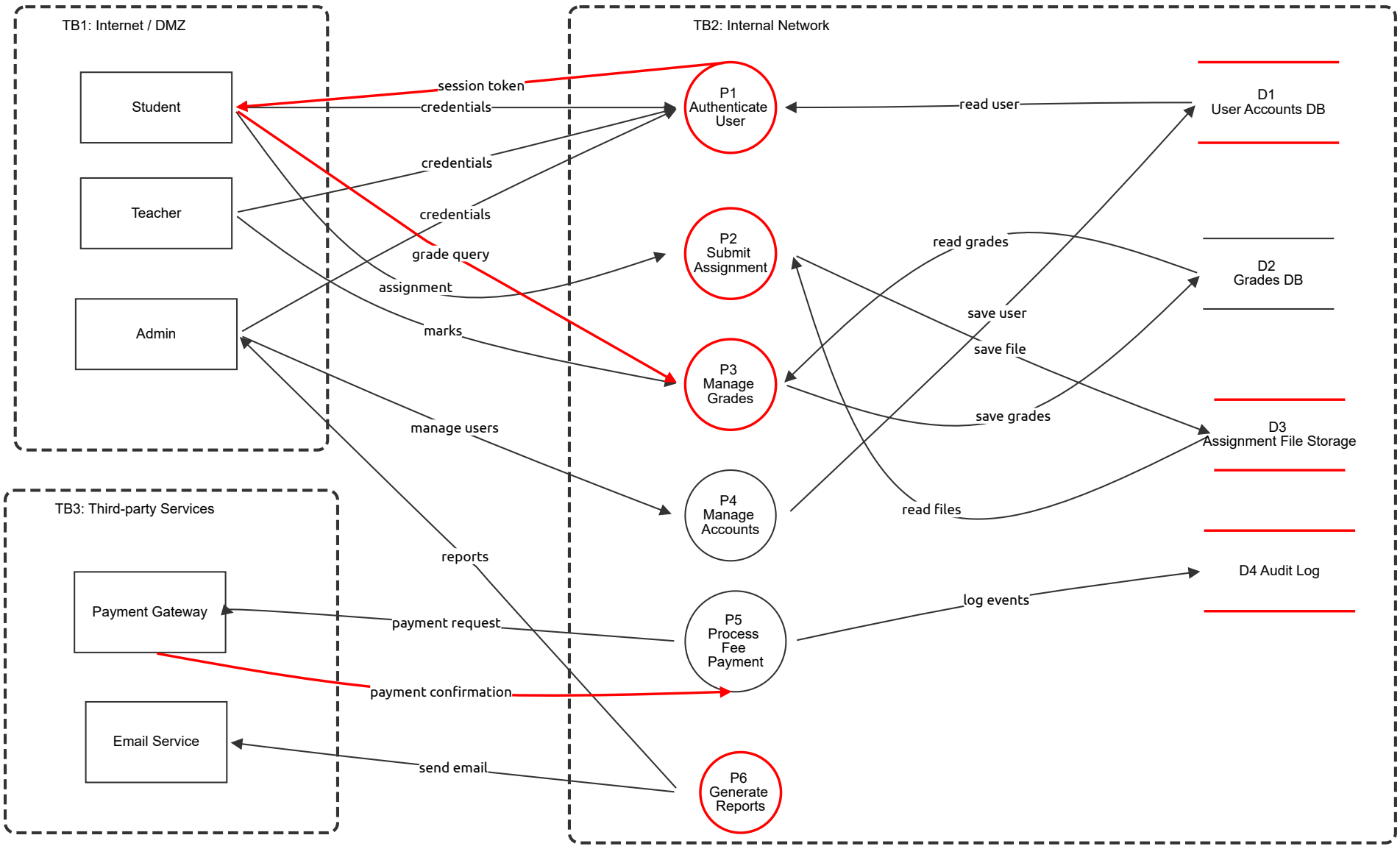
A university web portal for students to submit assignments and view grades, teachers to upload marks, and admins to manage accounts. The system uses a payment gateway for fees and an email service for notifications. It is hosted on a web server in a DMZ, connecting to an internal application server, database, and file storage.

Summary

Total Threats	12
Total Mitigated	1
Total Open	11
Open / Critical Severity	0
Open / High Severity	6
Open / Medium Severity	4
Open / Low Severity	1

SmartCampus Level 1 DFD

Level 1 Data Flow Diagram for the SmartCampus Online Exam and Result Portal. Models external entities, processes (P1-P6), data stores (D1-D4), and three trust boundaries (TB1-TB3).



SmartCampus Level 1 DFD

Student (Actor)

Description: External user who logs in, uploads assignments, and views grades/fee status

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Teacher (Actor)

Description: External user who logs in, uploads marks, and downloads submitted assignments.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Admin (Actor)

Description: Internal user who manages accounts, resets passwords, and generates reports.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Payment Gateway (Actor)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Email Service (Actor)

Description: Third-party external service used to send system notifications to users.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P1 Authenticate User (Process)

Description: Validates credentials. Students/Teachers use password; Admins use password + OTP.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Brute-force attack on teacher login	Spoofing	High	Open	16	An attacker runs an automated tool against the login page to guess a teacher's password. The login allows unlimited attempts, allowing the attacker to take over the account and change student marks.	Lock the account after 5 failed attempts, add rate limiting, enforce 12-character passwords, and offer MFA for teachers.

P2 Submit Assignment (Process)

Description: Handles student assignment uploads and routes the files to storage.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Student alters assignment file after submission	Tampering	Medium	Open	9	A student submits an assignment, then finds a way to overwrite the file in D3 directly before the teacher downloads it, replacing a poor submission with a better one.	Make D3 write-once for students, use cryptographic hashes (SHA-256) to verify file integrity upon download.

P3 Manage Grades (Process)

Description: Allows teachers to upload marks and students to view their grades.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	Student alters grade ID in URL	Elevation of privilege	High	Open	20	A student notices their student_id=101 in the browser address bar and changes it to student_id=102. The system lacks proper authorization checks, allowing the student to view another student's grades.	Implement strict server-side access control checks (ensure the logged-in user matches the requested ID) and use indirect object references.
4	Result-day traffic floods portal	Denial of service	High	Open	15	On result day, 5,000 students try to access the portal at the exact same time. The web server is overwhelmed, crashes, and legitimate students cannot view their grades.	Implement rate limiting, use a load balancer with auto-scaling, and cache static results pages.

P4 Manage Accounts (Process)

Description: Allows admins to create users, reset passwords, and manage roles.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Admin account has default password	Spoofing	Low	Mitigated	5	The test server has a default admin account (admin/admin). If this configuration is copied to production, an attacker can easily guess the credentials.	Force a password change on first login and enforce a complex password policy.

P5 Process Fee Payment (Process)

Description: Communicates with the Payment Gateway to verify fee transactions.

Properties: Card payment

Number	Title	Type	Severity	Status	Score	Description	Mitigations

credentials (Data Flow)

Description: Login credentials (username and password) sent from the user to the authentication process.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations

credentials (Data Flow)

Description: Login credentials sent from the teacher to the authentication process.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations

credentials (Data Flow)

Description: Login credentials (with OTP) sent from the admin to the authentication process.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations

session token (Data Flow)

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	Session token stolen on the network	Information disclosure	High	Open	16	A student logs in on a public university Wi-Fi network without HTTPS. An attacker sniffs the network traffic, steals the session token, and hijacks the student's active session.	Enforce TLS (HTTPS) on all data flows, set secure and HttpOnly flags on cookies.

assignment (Data Flow)

Description: Assignment file uploaded by the student to be processed.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations

marks (Data Flow)

Description: Grade data uploaded by the teacher to be saved.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations

grade query (Data Flow)

Description: Student requesting to view their specific grades.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	SQL injection in grade search	Tampering	High	Open	20	A student enters ' OR 1=1 -- into the grade query field. The application concatenates this directly into an SQL query, returning all grades in the database.	Use parameterized queries (prepared statements) in P3 to separate data from code, and implement input validation.

manage users (Data Flow)

Description: Admin requests to create, modify, or delete user accounts.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations

reports (Data Flow)

Description: Generated result report sent back to the Admin.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations

payment request (Data Flow)

Description: Fee payment details sent to the external gateway for processing.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

payment confirmation (Data Flow)

Description: Transaction success/failure response returned by the gateway.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Fake payment confirmation sent	Tampering	High	Open	20	The payment gateway sends fee confirmations to P5 without a cryptographic signature. An attacker intercepts the flow and sends a fake "success" response, allowing a student to bypass fee payment.	Require cryptographic signatures on all payment callbacks and verify the signature in P5 before updating the database.

send email (Data Flow)

Description: Notification data sent to the external email service.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

log events (Data Flow)

Description: Transaction logs written to the audit log for accountability.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

save file (Data Flow)

Description: Assignment file routed to physical file storage.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

save user (Data Flow)

Description: New or updated user details written to the database.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

read user (Data Flow)

Description: Authentication queries the database to verify credentials.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

save grades (Data Flow)

Description: Student marks written to the Grades database.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

read grades (Data Flow)

Description: Process queries the database to retrieve student marks.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

read files (Data Flow)

Description: Process retrieves the stored file to be downloaded.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P6 Generate Reports (Process)

Description: Compiles student data and results into reports for the Admin.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	Report generation crashes server	Denial of service	Low	Open	6	An Admin requests a massive report for all students across all semesters. The query consumes all server memory, causing the portal to go offline for other users.	Run heavy report generation in a background queue, limit the date range for reports, and implement timeout limits.

D1 User Accounts DB (Store)

Description: Stores user credentials, roles, and profile information.

Properties: Stores Credentials

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Unencrypted backup of user DB	Information disclosure	Medium	Open	12	The database administrator takes a nightly backup of D1 and stores it on a shared network drive without encryption. An attacker gains access to the drive and steals all user credentials.	Encrypt database backups at rest, store them in a secure offline location, and restrict access.

D2 Grades DB (Store)

Description: Stores student marks and exam results.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

D3 Assignment File Storage (Store)

Description: Stores uploaded student assignment files.

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Uploaded file contains malware	Tampering	Medium	Open	8	A malicious student uploads a PDF assignment that contains a hidden executable virus. When the teacher downloads the file to grade it, the malware infects the teacher's computer.	Scan all uploaded files with antivirus software, restrict file types to PDF/DOCX, and disable macros.

D4 Audit Log (Store)

Description: Stores system logs, failed logins, and transaction history.

Properties: Is a Log

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Marks changed without an audit trail	Repudiation	Medium	Open	10	A teacher changes a student's grade directly in the database but denies doing so. Because the system does not log database changes or timestamps, the university cannot prove who made the change.	Implement a write-only Audit Log (D4) that records all grade changes with the user ID, timestamp, and old/new values.